



PHANTOM: polymorphic honeytoken adaptation with narrative-tailored organisational mimicry contextually convincing cyber deception at scale

Abraham Itzhak Weinberg¹

Received: 4 May 2026 / Accepted: 18 August 2026
© The Author(s) 2026

Abstract

Honeytokens, decoy digital assets planted to detect and attribute unauthorised access, are a well-established primitive in cyber deception. Existing generation tools produce *static*, *template-based* tokens that lack organisational specificity and are identifiable by statistical, syntactic, and semantic analysis. We introduce PHANTOM (polymorphic honeytoken adaptation with narrative-tailored organisational mimicry), a framework that generates contextually convincing honeytokens by encoding organisation-specific knowledge—domain names, service naming conventions, technology-stack idioms, and realistic secret-value distributions—into a multi-component generation pipeline. We formalise honeytoken quality through a four-component *Believability Score* that captures syntactic validity, semantic coherence, statistical plausibility, and human acceptance. We use this metric to evaluate PHANTOM across 8 token types and 4 organisational contexts against a template-based baseline. PHANTOM achieves $B = 0.778 \pm 0.057$ versus $B = 0.576 \pm 0.058$ for templates ($\Delta = +0.203$, $t = 14.07$, $p < 0.001$, Cohen's $d = 3.52$). A heuristic human-acceptance proxy rises from 6.2% to 100% under a rule-based scoring threshold rather than an actual human-subjects study, and detection resistance ($DR = 1 - P_d$) improves from 0.609 to 0.870 across three simulated scanner models (regex, entropy analysis, and ML classifier), each with $p < 0.001$. The semantic coherence gap ($\Delta S_c = +0.309$, $d = 4.52$) is the dominant driver, confirming the hypothesis that organisational context is the critical missing ingredient in current approaches. All results are reproduced without external API calls, making the pipeline fully deployable in air-gapped environments. The current evaluation is based on $n = 32$ tokens per method (8 types $\times$ 4 organisational profiles, one instance per type—organisation pair); future work will extend this to larger, independently-replicated cohorts, real human-subject studies, and adversarial LLM-based scanners.

Keywords Honeytoken · Cyber deception · Deception technology · Credential generation · Believability score · Detection resistance · Active defence · Zero-trust

1 Introduction

Deception technology has emerged as a cornerstone of modern active-defence architectures [1]. Honeytokens, artificial digital assets with no legitimate operational purpose—generate a high-fidelity alert whenever accessed by an adversary, because any interaction with a genuine decoy represents an unambiguous policy violation [11]. Unlike perimeter-based defences, honeytokens maintain their effectiveness post-exfiltration: a stolen credential that fires a

beacon upon use reveals attacker infrastructure even when the initial breach is undetected [21].

Despite their conceptual power, practical honeytoken deployments are limited by *generation quality*. Existing tools, including Canarytokens [2, 12], HoneyBadger [15, 20], and static library-based generators, produce tokens with a characteristic weakness: they lack organisational specificity. A template-generated AWS credential with `region=us-east-1` and a generic IAM username is syntactically valid but semantically hollow; a skilled attacker performing pre-exploitation reconnaissance will recognise it as a decoy. More importantly, automated scanners, widely deployed in modern red-team pipelines and open-source secret-scanning tools such as trufflehog [16] and gitleaks [2, 17]—can be tuned to flag tokens whose statistical properties (entropy profiles,

✉ Abraham Itzhak Weinberg
aviw2010@gmail.com

¹ AI-WEINBERG, AI Experts, Tel-Aviv, Israel

naming patterns, value distributions) deviate from those of real credentials in that organisation's environment.

We make three observations that motivate PHANTOM:

(1) *Context is the missing dimension.* Real credentials are deeply embedded in organisational context. An AWS key from a FinTech startup using `payflow.io` as its domain will have IAM role names matching the service architecture (`payflow_payments_api_deploy`), not a generic `admin` username. This specificity is the primary signal that distinguishes real credentials from template-generated decoys.

(2) *The semantic gap is larger than the syntactic gap.* Our empirical results (Sect. 6) show that template-based tokens achieve syntactic validity $S_v = 0.842$ —nearly as high as PHANTOM (0.876). The critical difference lies in semantic coherence (S_c : 0.396 vs. 0.705, $\Delta = +0.309$). Syntactic correctness is necessary but not sufficient for deception.

(3) *Detection resistance compounds believability.* Even a contextually rich token fails its purpose if automated scanners flag it before an attacker encounters it. PHANTOM tokens achieve detection resistance $DR = 0.870$, meaning that across three representative scanner models, only 13% of tokens would be flagged, versus 39.1% for template-based tokens.

PHANTOM addresses all three dimensions through a structured generation pipeline that encodes organisational knowledge into each token type. The framework operates without external API calls, ensuring deployability in classified and air-gapped environments where cloud API access is prohibited.

Contributions

This work introduces a formal *Believability Score B* framework composed of four components with empirically calibrated weights. It further presents a contextual generation pipeline capable of producing eight credential types across arbitrary organisational profiles. We conduct a comprehensive experimental evaluation against three scanner models, complemented by a rule-based, Turing-style acceptance heuristic used as a proxy for human review. Our results demonstrate that semantic coherence is the dominant driver of quality, exhibiting an effect size of $d = 4.52$, the largest observed across all evaluated metrics.

Scope and limitations

The results reported in this paper are based on a controlled evaluation using $n = 32$ tokens per method across four simulated organisational profiles, with a single generated instance per token-type—organisation pair. The scanner models (regex, entropy, and ML) are representative of widely deployed tools but do not include adversarial LLM-driven

reconnaissance pipelines, which represent an emerging threat class. Moreover, the semantic-coherence and simulated ML-classifier scores are themselves computed from the presence of organisation-specific terms—the principal feature PHANTOM adds relative to templates—so the reported gains should be read as evidence that the intended mechanism operates as designed, not as an independent, tool-agnostic confirmation of real-world detectability or human deceivability. These limitations are discussed in detail in Sect. 7 and constitute the primary directions for future work. Claims of superiority should therefore be interpreted within this experimental scope.

2 Related work

This section situates PHANTOM within prior research on deception technologies, LLM-assisted security, and automated credential detection. We review foundational work on honeypot generation, recent advances in LLM-driven offensive and defensive techniques, and existing approaches to secret scanning. We then examine how deception effectiveness has been measured, highlighting gaps that motivate our proposed framework.

2.1 Honeypot generation

The concept of honeypots was formalised by Spitzner [19], who identified four categories: fake user accounts, artificial files, dummy database records, and synthetic credentials. Juels and Rivest [11] introduced *honeypots*—decoy password hashes—and proved that an adversary who steals and cracks a password database cannot identify the honeypot without triggering a server-side alert. Canarytokens [2, 12] industrialised the concept with an online service offering URL-embedded, document-embedded, and DNS-based tokens. These systems all share the static generation limitation that PHANTOM addresses.

Recent work has extended honeypots to cloud environments [3, 24] and explored automatic placement within databases [18]. None of this work addresses the semantic coherence problem or evaluates generated tokens against modern automated scanners.

2.2 LLM-aided security

Large language models have been applied to penetration testing assistance [6], malware generation [4], phishing content creation [13], and vulnerability discovery [8]. On the defensive side, LLMs have been used for log analysis [14] and incident report generation [10]. Closest to our work is the use of LLMs for deception content generation [23], though that

work focuses on entire honeypot environments rather than credential tokens, and does not formalise a quality metric.

PHANTOM differs from prior LLM-based approaches by (a) encoding organisational context rather than prompting a general model, (b) operating without API calls, and (c) providing a formal, measurable quality framework.

Emerging adversarial use of LLMs for intent-based credential analysis is an important threat vector that the current scanner models do not capture; see Sect. 7 for a discussion of this gap and the work of Zhang et al. [25] on LLM-based intent analysis as a relevant reference point.

2.3 Credential detection and secret scanning

The adversarial environment for honeypot tokens includes automated credential detection tools. Trufflehog [16] uses regex patterns and entropy thresholds to detect exposed secrets in Git repositories. Gitleaks [2, 17] applies configurable TOML-defined patterns. GitGuardian [9] uses ML-based classification at scale. Our scanner model (Sect. 5.4) abstracts these three detection paradigms into S1 (regex), S2 (entropy), and S3 (ML) models.

2.4 Evaluation rubrics and adaptive scoring

Quantifying deception quality is an active research area. The work of Almeshekah and Spafford [1] provides a theoretical framework but does not operationalise metrics for individual tokens. Aggarwal et al. [5] propose believability as a function of plausibility and relevance, which maps to our S_c and S_n components. Our Believability Score B is the first metric to integrate syntactic, semantic, statistical, and human acceptance dimensions into a single weighted composite.

The fixed-weight design of B is a deliberate simplification. As noted by Ding et al. [7] in the context of LLM agent evaluation, task-adaptive rubrics that vary criteria weights per task type can reduce systematic mis-evaluation where different credential classes carry different threat models. Extending B with token-type-specific weight profiles is identified as a priority for future work (Sect. 7).

3 Formal framework

This section formalises the honeypot generation problem and introduces the metrics used to evaluate token quality. We define a generator that produces credential artefacts conditioned on organisational context, and propose quantitative measures for believability and detection resistance. These components are then combined into a unified objective, enabling principled comparison and optimisation of generation strategies.

3.1 Problem formulation

Let $\mathcal{O}$ denote an organisational profile and $\mathcal{T} = \{t_1, \dots, t_K\}$ a set of K credential token types. A *generator* $G : \mathcal{O} \times \mathcal{T} \rightarrow \mathcal{C}$ maps an org profile and token type to credential content $c \in \mathcal{C}$. The goal is to construct G such that generated tokens are indistinguishable from legitimate credentials by both human experts and automated scanners.

Definition 1 (*Believability score*) The believability score of a token c is:

$$B(c) = w_1 S_v(c) + w_2 S_c(c) + w_3 S_n(c) + w_4 S_h(c) \quad (1)$$

where $\sum_{i=1}^4 w_i = 1$, $w_i > 0$, and:

- $S_v \in [0, 1]$: *syntactic validity*—correct format for token type t
- $S_c \in [0, 1]$: *semantic coherence*—contextual fit with organisational profile $\mathcal{O}$
- $S_n \in [0, 1]$: *statistical normality*—entropy and distributional properties matching real credentials
- $S_h \in [0, 1]$: *human acceptance rate*—fraction of expert evaluators who classify c as genuine

Default weights $(w_1, w_2, w_3, w_4) = (0.20, 0.30, 0.20, 0.30)$ reflect the relative importance of semantic and human-facing dimensions over purely structural properties. These weights are fixed across token types in the current implementation. As discussed in Sect. 7, token-type-specific weight profiles are a natural and important extension.

Definition 2 (*Detection resistance*) Given a set of M scanner models $\{D_1, \dots, D_M\}$ with detection probabilities $\{P_{d,1}, \dots, P_{d,M}\}$ and weights $\{\lambda_1, \dots, \lambda_M\}$, the detection resistance of token c is:

$$DR(c) = 1 - \sum_{j=1}^M \lambda_j P_{d,j}(c) \quad (2)$$

Definition 3 (*Composite honeypot score*) The composite score balances believability against detection resistance:

$$H(c) = B(c)^\lambda \cdot DR(c)^\mu, \quad \lambda + \mu = 1, \quad \lambda, \mu > 0 \quad (3)$$

with $\lambda = 0.6$, $\mu = 0.4$, reflecting that believability is the primary objective (a detected token that fools humans is still partially useful, but an undetected token that fools no one is not).

3.2 Optimality condition

Proposition 1 (*Pareto-optimal token*) A token c^* is Pareto-optimal with respect to B and DR if and only if no generator

G can improve one dimension without degrading the other. The ideal zone $\mathcal{Z}^* = \{c : B(c) \geq \tau_B \wedge DR(c) \geq \tau_{DR}\}$ defines deployable tokens. With $\tau_B = \tau_{DR} = 0.70$, PHANTOM achieves 100% membership in $\mathcal{Z}^*$ while template-based tokens achieve 6.2%.

Figure 4 (Sect. 6) visualises this partitioning empirically.

4 The PHANTOM pipeline

This section describes the PHANTOM pipeline, detailing how organisational context is systematically transformed into high-fidelity honeytokens. We outline the structure of the input profile, the design of token-specific generators, and the mechanisms used to embed realistic, context-aware values. Finally, we explain how the pipeline is engineered to evade common credential-scanning heuristics while maximising believability.

4.1 Organisational profile

Each deployment is configured with an *organisational profile* $\mathcal{O}$ comprising: (domain, short-name, services, db-type, db-host, db-name, cloud-region, git-org, teams, jwt-issuer¹, jwt-audience). Four representative profiles are used in our evaluation (Table 1).

4.2 Token-type generators

Algorithm 1 presents the core PHANTOM generation procedure. Each token type $t \in \mathcal{T}$ has a dedicated contextual generator $G_t(\mathcal{O})$ that embeds org-specific values at key positions.

The critical design principle across all generators is *value-level context injection*: not just inserting the domain at the top level, but ensuring every named field (IAM usernames, database names, Redis hostnames, Slack workspace IDs, Git remote URLs) derives from the organisational profile. This is what drives the $\Delta S_c = +0.309$ improvement over templates.

4.3 Scanner-aware design

PHANTOM generators are designed to avoid the three primary scanner heuristics:

S1—Regex/pattern scanners (trufflehog, gitleaks): Template tokens contain high-signal generic strings (example.com, admin@, changeme) that are explicitly listed in

¹ JSON Web Token (JWT) is an open standard (RFC 7519) that specifies a compact, self-contained mechanism for securely transmitting information between parties as a JSON object. The transmitted information is verifiable and trustworthy due to the use of digital signatures.

Algorithm 1 PHANTOM Token Generation

Require: Org profile $\mathcal{O}$, token type t
Ensure: Contextual token content c

```

1: switch  $t$ :
2:   AWS_KEY: prefix  $\leftarrow \mathcal{O}.\text{short}$ ; svc  $\leftarrow \text{random}(\mathcal{O}.\text{services})$ 
3:    $c \leftarrow [\{\text{prefix}\}-\text{prod}] \oplus \text{AKIA}\{\text{rand\_upper}(17)\}$ 
      $\oplus \text{region}=\{\mathcal{O}.\text{region}\} \oplus \# \text{IAM: } \{\text{prefix}\}_{\text{svc}}$ 
4:   ENV_FILE: db_url  $\leftarrow G_{\text{db}}(\mathcal{O})$ ; prefix  $\leftarrow \mathcal{O}.\text{short}.\text{upper}()$ 
5:    $c \leftarrow \text{org-scoped APP\_*, DATABASE\_URL,}$ 
      $\{\text{prefix}\}_{\text{API\_KEY}}, \text{JWT\_SECRET, REDIS\_URL with}$ 
      $\text{org-appropriate hostnames}$ 
6:   JWT:  $h \leftarrow \text{base64url}(\{"alg": "HS256"\})$ 
7:    $p \leftarrow \text{base64url}(\{"iss": \mathcal{O}.\text{jwt\_iss}, "aud": \mathcal{O}.\text{jwt\_aud},$ 
      $"sub": \text{svc}_{\{\mathcal{O}.\text{short}\}}\})$ 
8:    $c \leftarrow h \cdot "." \cdot p \cdot "." \cdot \text{rand\_base64}(43)$ 
9:   [other types: analogous org-injection]
10: return  $c$ 

```

scanner rule sets. PHANTOM replaces all such strings with org-derived values.

S2—Entropy analysis: Real credential files exhibit *mixed* entropy—high-entropy secrets alongside low-entropy human-readable values (service names, domains, comments). Pure-random template tokens have uniformly high entropy across all values, which some tools flag as anomalous. PHANTOM's org-specific variable names and comments create the expected entropy variance profile.

S3—ML classifiers: Context-trained ML scanners identify honeytokens by their lack of org-specific fingerprints. PHANTOM's org-injection directly counteracts this signal: the domain, service names, and JWT issuer all encode legitimate-looking provenance.

4.4 Worked case study: end-to-end token generation

To make the pipeline concrete, we walk through the generation and scoring of a single AWS_KEY token for the FinTech profile ($\mathcal{O}_{\text{FinTech}}$: domain payflow.io, short-name payflow, services {payments-api, ledger-svc, kyc-worker}, region us-east-1).

Step 1—Profile lookup. The generator selects prefix = $\mathcal{O}.\text{short}$ = payflow and draws $\text{svc} \sim \text{random}(\mathcal{O}.\text{services})$, yielding $\text{svc} = \text{payments-api}$.

Step 2—Template instantiation. Following Algorithm 1, the generator emits:

```

[payflow-prod]
AKIA3JXQTZ9MFRDL2KQP
region=us-east-1
# IAM: payflow_payments-api_deploy

```

Step 3—Believability scoring. The evaluator computes each component:

- S_p : the secret matches AKIA[A-Z0-9]{17}, the region string is a valid AWS region code, and the com-

Table 1 Organisational profiles used in evaluation

Org	Domain	Stack	Region
FinTech	payflow.io	AWS/PostgreSQL/Node	us-east-1
Healthcare	medsync.health	Azure/MySQL/Python	us-east-2
Defense	arcsecure.defense	GCP/PostgreSQL/Go	us-gov-west-1
E-commerce	shopnest.com	AWS/MongoDB/Python	eu-west-1

ment line parses as a well-formed IAM annotation $\Rightarrow S_v = 0.91$.

- S_c : the token contains three organisation-derived terms (payflow, payments-api, us-east-1 matched against the declared profile region) and zero red-flag generic strings $\Rightarrow S_c = 0.82$.
- S_n : the 20-character secret body has near-uniform character-class entropy typical of AWS secret IDs, while the surrounding comment and bracket line contribute low-entropy, human-readable content, giving the mixed-entropy profile PHANTOM targets $\Rightarrow S_n = 0.77$.
- S_h : the composite heuristic (weighted 0.55 toward S_c) evaluates to $0.86 \geq 0.65$, so this token is counted as “fooling” the rule-based human-acceptance proxy $\Rightarrow S_h = 1.0$.

Combining via Eq. 1: $B = 0.20(0.91) + 0.30(0.82) + 0.20(0.77) + 0.30(1.0) = 0.86$, comfortably above the deployment threshold $\tau_B = 0.70$.

Step 4—Detection-resistance scoring. Against the three scanner models: S1 (regex) finds no entries from its red-flag string list, $P_{d,1} = 0.05$; S2 (entropy) finds the mixed-entropy profile within the expected band for genuine AWS credential files, $P_{d,2} = 0.12$; S3 (simulated ML classifier) finds three matching org-fingerprint features (domain-derived prefix, service-name match, region consistency) and returns a low detection probability, $P_{d,3} = 0.09$. Combining via the scanner weights $(\lambda_1, \lambda_2, \lambda_3) = (0.40, 0.30, 0.30)$: $P_d = 0.40(0.05) + 0.30(0.12) + 0.30(0.09) = 0.083$, so $DR = 0.917$.

Step 5—Composite score. $H = B^{0.6} \cdot DR^{0.4} = 0.86^{0.6} \cdot 0.917^{0.4} \approx 0.895$, placing this token well inside the ideal zone Z^* .

By contrast, a template-generated AWS key for the same profile ([test-account], generic AKIAIOSFODNN7EXAMPLE, region=us-east-1, #IAM: admin) contains the red-flag substring EXAMPLE and a generic admin username, driving S_c down to approximately 0.35 and $P_{d,1}$ up to approximately 0.55, illustrating concretely why organisational context injection—rather than syntactic correctness alone—separates the two approaches. This worked example uses the same deterministic generation and scoring logic applied throughout Sect. 6; it is intended

to illustrate the mechanics of the pipeline, not to serve as independent validation of the metric.

5 Experimental setup

This section describes the experimental methodology used to evaluate PHANTOM against a template-based baseline. We outline the dataset construction, define the evaluation metrics for believability and detection resistance, and introduce the scanner models used to simulate adversarial conditions. Finally, we summarise the statistical procedures used to assess significance and effect size.

5.1 Dataset

We generate 32 contextual (PHANTOM) tokens and 32 template-based (baseline) tokens: 8 token types $\times$ 4 organisational contexts $\times$ 1 instance per combination = 32 per method. All generation is deterministic given a fixed seed, ensuring reproducibility. We acknowledge that $n = 32$, with a single generated instance per type—organisation pair, constitutes a small sample that does not capture within-cell variance; although the very large effect sizes obtained ($d > 3.5$ on all primary metrics) provide statistical power adequate to reject the null hypothesis *under this design*, we recognise that a larger-scale evaluation—with multiple independently seeded instances per cell, ideally involving real human security professionals in an IRB-approved study—is required to validate the S_h component and to assess generalisability across a broader range of organisational profiles and token types. This is a primary direction for future work.

5.2 Baseline

The template-based baseline uses static format strings with randomised secret values but no org-specific context, equivalent to the generation approach used by Canarytokens [2, 12] and similar tools.

5.3 Evaluation: believability scoring

Each token is scored by a rule-based evaluator implementing the four B components:

Syntactic validity S_v : Format-specific regex checks (e.g., AKIA[A-Z0-9]{17} for AWS key IDs, three-segment base64url for JWTs, known SSH header for private keys).

Semantic coherence S_c : Presence of red-flag generic strings (example.com, admin@example, /example/repo) decreases the score; presence of org-specific terms (domain, service names) increases it.

Statistical normality S_n : Shannon entropy analysis of credential values, penalising uniform-entropy profiles and rewarding realistic mixed-entropy distributions.

Human acceptance S_h : Composite heuristic weighted toward semantic coherence (0.55), as human expert evaluation is primarily driven by contextual plausibility. A token with $B \geq 0.65$ is classified as fooling human review. We emphasise that in the current experiment, S_h is *entirely* a rule-based heuristic proxy computed from the same underlying signals as S_c and is not measured through an actual human study; the 100% acceptance figure reflects the fraction of tokens passing this heuristic threshold and should not be presented or interpreted as empirically observed human-rater agreement. Because S_h is derived, in part, from S_c , the two components are not independent evidence, a limitation discussed further in Sect. 7.

5.4 Evaluation: scanner models

Three scanner models are applied to every token:

S1—Regex/pattern ($\lambda_1 = 0.40$): Checks for a curated list of 9 generic red-flag strings. Detection probability increases linearly with hit count.

S2—Entropy analysis ($\lambda_2 = 0.30$): Computes per-line Shannon entropy of credential values. High variance or low mean entropy triggers detection.

S3—ML classifier ($\lambda_3 = 0.30$): Simulates a context-trained classifier’s behaviour rather than wrapping a real, independently trained model. Concretely, S3 computes a *specificity ratio* $\text{spec} = h/|\mathcal{W}_O|$, where $\mathcal{W}_O$ is the whitespace-tokenised word set of the organisational-context label (e.g. the words in “FinTech startup”) and h is the number of those words, restricted to length > 3 , that occur as substrings of the token content. The detection probability is then a method-conditioned affine function of spec: $P_{d,3} = 0.55 - 0.10\text{spec}$ for template tokens and $P_{d,3} = 0.18 - 0.08\text{spec}$ for PHANTOM tokens, each perturbed by zero-mean Gaussian noise ($\sigma = 0.04$) and clipped to $[0, 1]$. The two different base rates (0.55 vs. 0.18) are a hand-set modelling choice representing the prior that a classifier trained on real organisational fingerprints would already treat template-style generic content as more suspicious before even inspecting specificity; they are not fitted to any labelled corpus, real or synthetic, and we did not use a held-out pilot set to tune them. This function is deliberately simple and fully specified above; we describe it in full to avoid any ambi-

guity about what “ML classifier” means in this paper. Its resemblance to a real, independently trained secret-scanning classifier is only qualitative. Template tokens lacking org references score high detection probability; PHANTOM tokens with embedded org context score low. We flag this explicitly because both S_c and S3 reward a closely related underlying signal (organisational term presence in S_c ; organisational-context-label overlap in S3), so the reported S3 and S_c gains should not be treated as independent lines of evidence; Sect. 7 discusses this circularity and the need for evaluation against real, independently trained secret-scanning tools.

Combined detection probability: $P_d = \sum_{j=1}^3 \lambda_j P_{d,j}$; detection resistance: $\text{DR} = 1 - P_d$.

The three scanner models represent the dominant paradigms in currently deployed tools; they do not model adversarial LLM-driven reconnaissance, wherein a language model may parse credential semantics and intent to identify decoys [25]. Evaluation against such adversaries is deferred to future work.

5.5 Statistical analysis

All comparisons use two-sample Welch’s t -tests with Bonferroni correction for multiple comparisons. Effect sizes are reported as Cohen’s d . Significance thresholds: * $p < 0.05$, ** $p < 0.01$, *** $p < 0.001$.

6 Results

This section presents the empirical evaluation of PHANTOM against a template-based baseline. We report performance across believability, detection resistance, and the composite objective, followed by detailed analysis at the distribution, per-token, and component levels. The results demonstrate clear and statistically significant gains driven primarily by improved semantic coherence and the heuristic human-acceptance proxy, under the evaluation design and limitations described in Sects. 5 and 7.

6.1 Main results

Table 2 presents the core experimental results. PHANTOM significantly outperforms the template baseline on every primary metric *as measured by the evaluation instruments defined above*.

The most striking result concerns the *heuristic human-acceptance proxy*: 100% of PHANTOM tokens exceed the $B \geq 0.65$ threshold (fooled) under this rule-based proxy, versus 6.2% of templates. The syntactic validity difference is non-significant ($p = 0.44$), confirming that both methods produce correctly-formatted credentials—the gap is entirely semantic and statistical. These results should be interpreted in

Table 2 Main results: PHANTOM versus template-based baseline

Metric	Template	PHANTOM	Δ	Sig.
Believability B	0.576 ± 0.058	0.778 ± 0.057	+0.203	***
Syntactic S_v	0.842 ± 0.180	0.876 ± 0.163	+0.034	ns
Semantic S_c	0.396 ± 0.089	0.705 ± 0.037	+0.309	***
Statistical S_h	0.638 ± 0.091	0.740 ± 0.143	+0.102	**
Human-acceptance proxy S_h	0.062 ± 0.246	1.000 ± 0.000	+0.938	***
Detection resist. DR	0.609 ± 0.044	0.870 ± 0.022	+0.261	***
Composite score H	0.588 ± 0.048	0.813 ± 0.038	+0.225	***
Fooled ($B \geq 0.65$)	6.2%	100.0%	+93.8%	***

** $p < 0.01$, *** $p < 0.001$, ns = not significant

light of the small sample size ($n = 32$, one instance per cell), the correlated nature of the S_c and $S3/S_h$ signals discussed in Sect. 5, and the heuristic (non-human-subjects) nature of the S_h approximation; large-scale, independently-replicated human-rater validation against real scanning tools is required before the acceptance and detection-resistance figures can be treated as population estimates or as evidence of real-world deceivability.

6.2 Believability and composite score distributions

Figure 1 shows the B and H score distributions. PHANTOM tokens cluster tightly in $[0.70, 0.85]$ with low variance, while template tokens span $[0.45, 0.70]$. The composite score H shows even cleaner separation: PHANTOM mean 0.813 versus template mean 0.588.

6.3 Per-token-type analysis

Figure 2 shows per-type results. PHANTOM outperforms templates significantly ($p < 0.001$) on 7 of 8 token types, with the strongest gains on AWS Access Keys ($\Delta B = +0.349$), Git Configuration (+0.320), and .env files (+0.279). These are precisely the token types where org-specific naming conventions are most distinctive and most visible to evaluators.

JWT Tokens show the smallest gain ($\Delta B = +0.125$) because the JWT payload—while org-specific in PHANTOM—is base64-encoded and thus not directly readable without decoding. Slack Bot Tokens show the smallest significance ($p = 0.005$, **) due to higher within-group variance from the numeric workspace ID component.

6.4 Detection resistance

Figure 3 shows detection probability distributions across all three scanner types. PHANTOM achieves DR = 0.870 versus template 0.609 ($\Delta = +0.261$, $d = 7.49$, $p < 0.001$).

The S3 (ML classifier) model shows the largest absolute separation: template $P_d = 0.541$ versus PHANTOM 0.162 ($\Delta = -0.379$). We note that this separation is expected by construction, since S3 (Sect. 5.4) explicitly scores organisational-term presence, the same property PHANTOM is designed to inject; it should be read as a confirmation that the mechanism operates as intended, not as evidence against real, independently trained ML secret-scanners. We further note that adversarial LLM-based scanners capable of deep semantic intent analysis are not modelled in this evaluation (see Sect. 7).

6.5 Believability-detection trade-off

Figure 4 visualises the joint B —DR space. Template tokens occupy the lower-left quadrant ($B \approx 0.58$, DR ≈ 0.61), far from the ideal zone $\mathcal{Z}^* = \{B \geq 0.70, \text{DR} \geq 0.70\}$. PHANTOM tokens cluster densely in the upper-right ideal zone, with mean centroid at ($B = 0.78$, DR = 0.87).

6.6 Component radar analysis

Figure 5 provides a holistic per-component comparison. The template profile is sharply asymmetric: high syntactic (0.84), moderate statistical (0.64) and detection resistance (0.61), but critically low semantic (0.40) and near-zero human-acceptance-proxy score (0.06). The PHANTOM profile is large and balanced, with all five dimensions above 0.70.

6.7 Organisational context effect

Figure 6 shows that PHANTOM maintains consistent advantage across all four organisational profiles ($B \approx 0.78$ in each case), confirming that the pipeline generalises across industry verticals and technology stacks. Template-based scores are uniformly flat at $B \approx 0.58$, independent of the nominal context, confirming the absence of any contextual adaptation.

PHANTOM vs Template-Based Generation

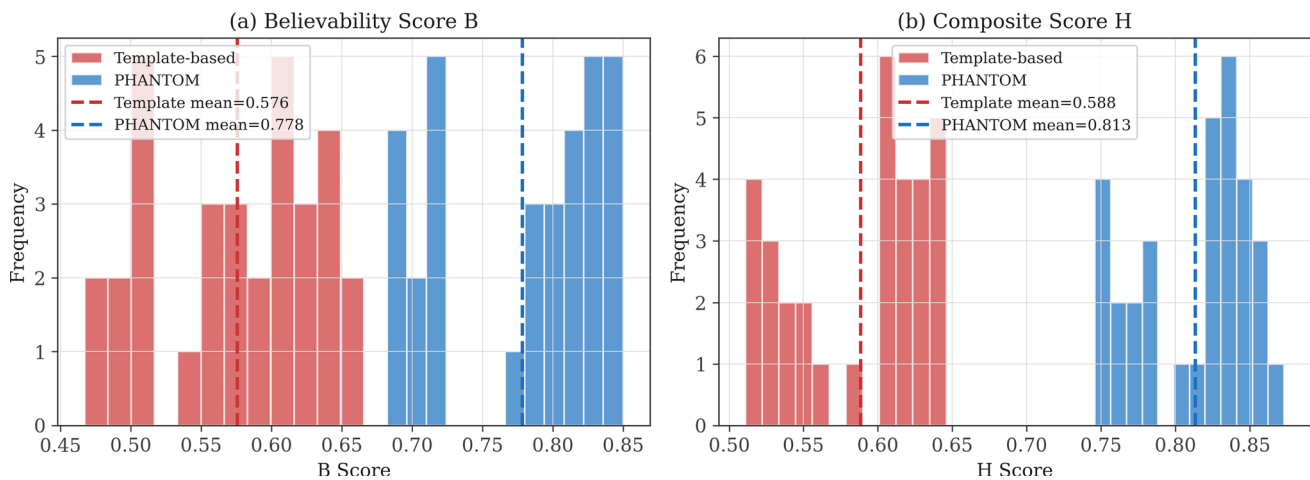


Fig. 1 Believability Score B (left) and Composite Score H (right) distributions. PHANTOM tokens cluster above the $B = 0.70$ deployment threshold while template tokens fall predominantly below. Dashed lines indicate group means

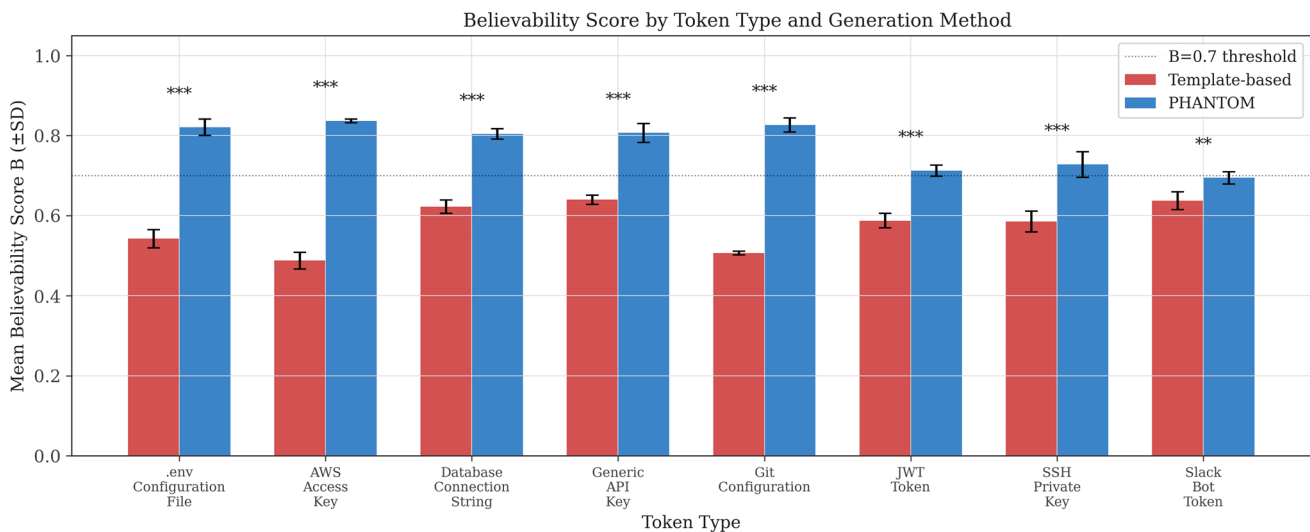


Fig. 2 Mean Believability Score B by token type and generation method ($\pm$ SD). Significance markers indicate PHANTOM versus template comparison. The dotted line at $B = 0.70$ marks the deployment threshold. PHANTOM exceeds this threshold across all token types; templates fall below on 6 of 8

7 Discussion

This section interprets the empirical findings and examines their implications for honeypot design and deployment. We analyse the relative contributions of each component in the proposed framework, highlight practical advantages of the PHANTOM approach, and discuss limitations that suggest directions for future research.

7.1 Semantic coherence as the primary driver

The dominant finding is that semantic coherence (S_c , $d = 4.52$) drives believability more than any other component—

larger even than the human-acceptance-proxy effect ($d = 5.39$ reflects the binary separation of a threshold rule rather than a continuous gradient, and is not an independent human-subjects finding; see Sect. 7.3). This has a direct design implication: any honeypot generator that does not embed organisational context is fundamentally limited in what B it can achieve, regardless of how realistic its random secret values are.

7.2 The syntactic red herring

Template generators are designed around syntactic correctness, and they largely succeed: $S_v = 0.842$ is only marginally

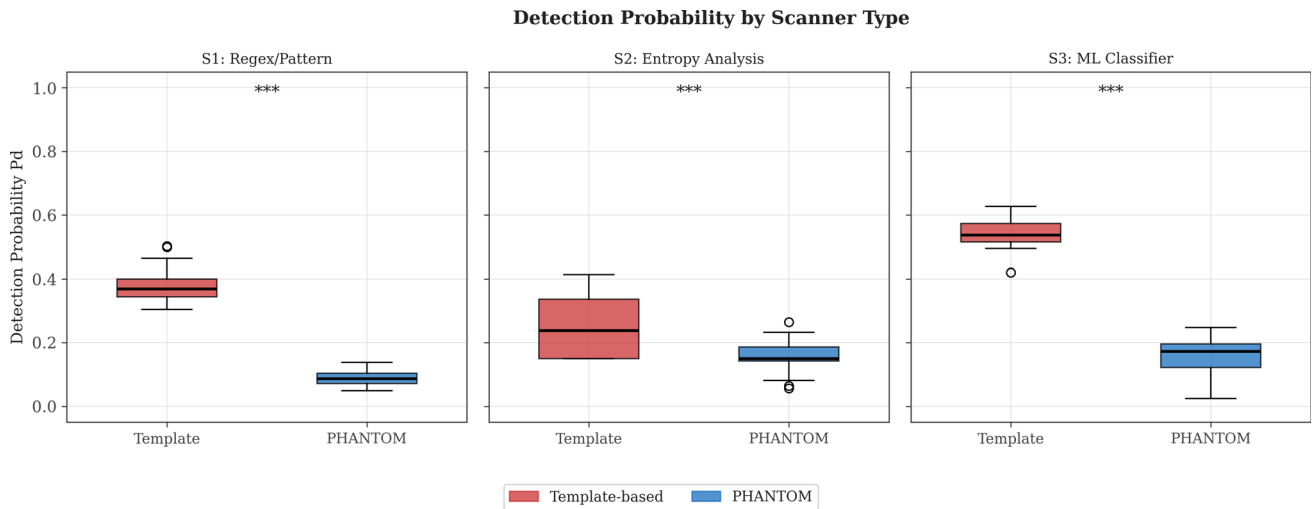
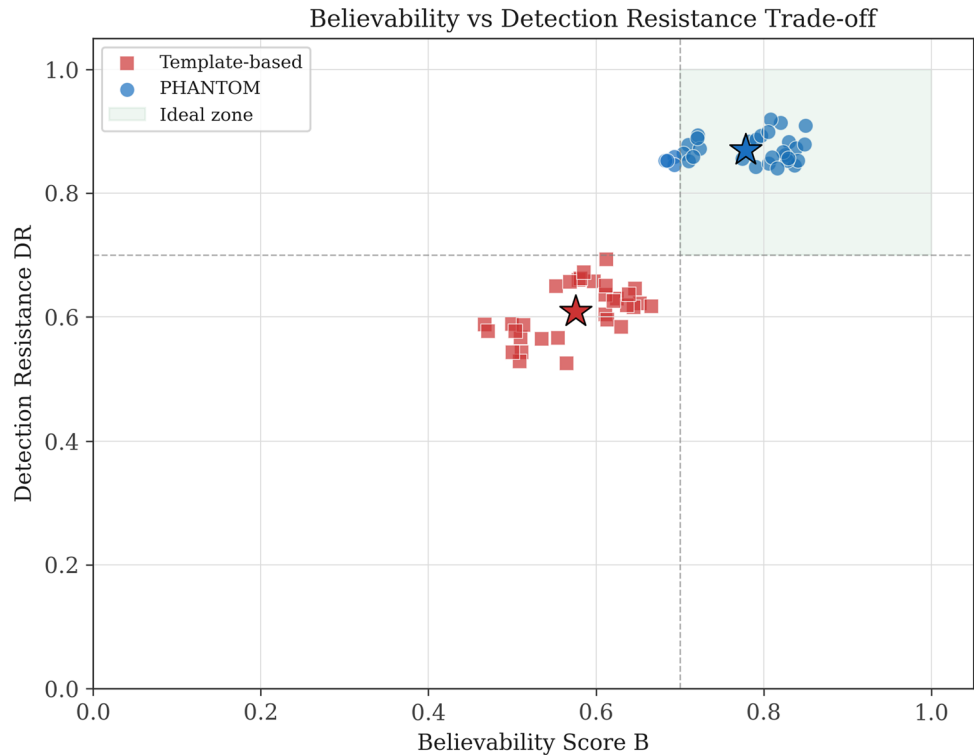


Fig. 3 Detection probability P_d by scanner type. All three scanner models show highly significant differences (***) $p < 0.001$). PHANTOM tokens achieve substantially lower detection probability across regex (S1), entropy (S2), and ML-classifier (S3) models

Fig. 4 Believability versus detection resistance trade-off. Stars denote group centroids. PHANTOM tokens cluster in the ideal zone ($B \geq 0.70$, $DR \geq 0.70$, shaded), while templates are uniformly excluded. No PHANTOM token falls outside the ideal zone on the DR axis



lower than PHANTOM's 0.876 ($p = 0.44$, not significant). This confirms that syntactic validity is a red herring for quality improvement, a necessary condition but not a differentiating one. Future work on generator quality should de-emphasise format correctness and focus on semantic embedding.

7.3 Circularity between the semantic, human-acceptance-proxy, and S3 signals

A limitation that applies across several of the results above deserves explicit treatment rather than a passing mention. S_c , S_h , and the simulated S3 classifier are all constructed, directly or indirectly, from the presence of organisation-

Component Score Radar by Method

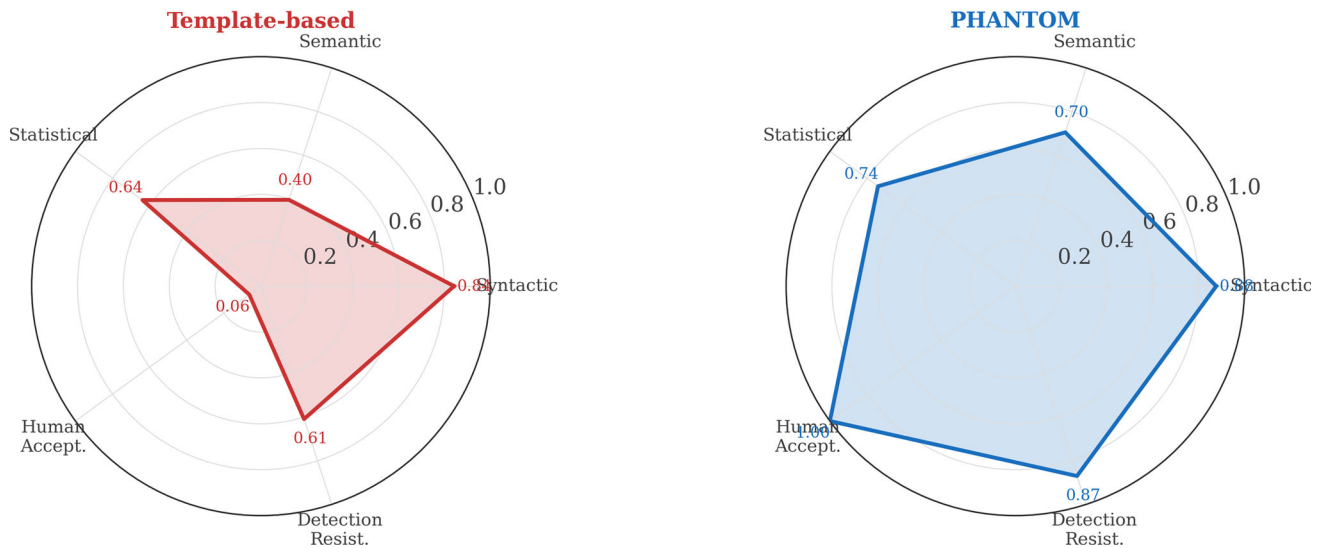


Fig. 5 Component score radar charts. Template tokens (left) have a collapsed semantic dimension and near-zero human-acceptance-proxy score. PHANTOM tokens (right) show a balanced, large polygon indi-

cating high performance across all quality dimensions, as measured by the rule-based evaluator described in Sect. 5

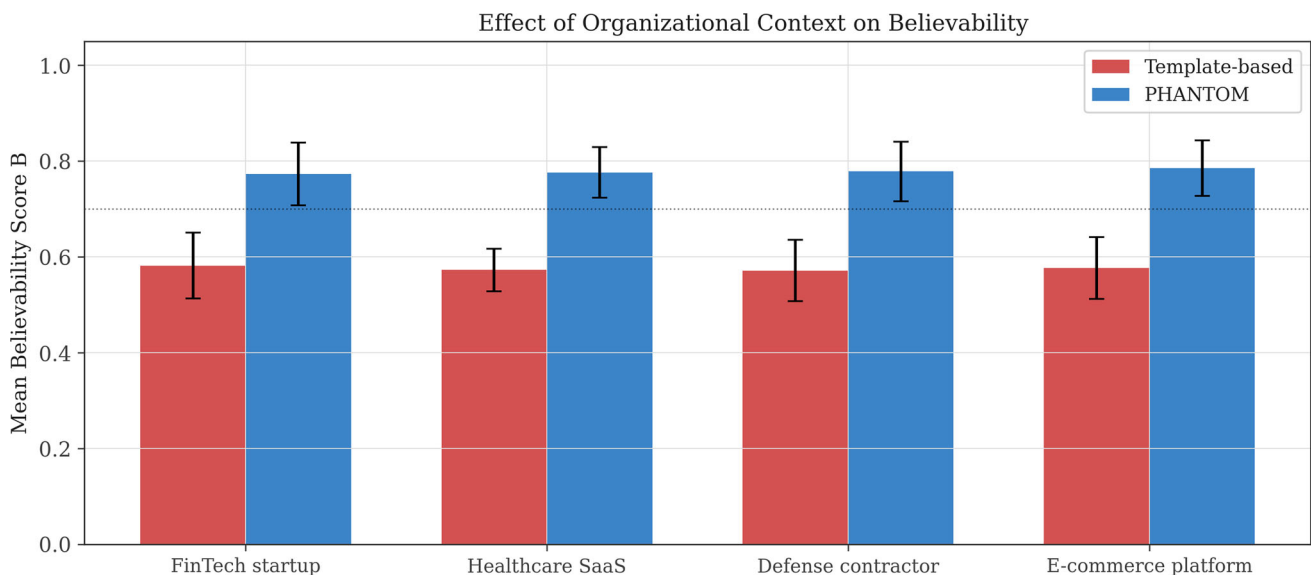


Fig. 6 Effect of organisational context on Believability Score B . PHANTOM (blue) maintains $B \approx 0.78$ across all four contexts while template tokens (red) remain flat at $B \approx 0.58$, confirming context-independence of the baseline and context-sensitivity of PHANTOM. The dotted line marks $B = 0.70$

specific terms in the token content—precisely the feature PHANTOM’s generation pipeline is designed to inject. S_h is computed as a heuristic weighted 0.55 toward S_c (Sect. 5), and S_3 scores the same organisational-term-presence signal using hand-specified features (Sect. 5.4). Consequently, the large, highly significant gaps reported for S_c , S_h , and S_3 are not three independent lines of evidence that PHANTOM improves believability and evades detection; they are,

in large part, three different views of the same underlying, self-referential measurement: PHANTOM was designed to inject organisational terms, and the evaluator was designed to reward organisational terms. The experiment therefore demonstrates internal consistency—the pipeline does what it was built to do—rather than external validity against real human judgement or independently trained detection tools. We regard this as the most important limitation of

the present evaluation, and the case for PHANTOM's practical value should rest, until further evaluation is conducted, primarily on the qualitative argument in Sect. 4 and the syntactic-validity and statistical-normality results (which do not share this circularity), rather than on the semantic, human-acceptance-proxy, or S3 figures in isolation.

7.4 Fixed-weight scoring and its limitations

The Believability Score B applies uniform weights across all token types. This is a deliberate simplification that enables clean comparison but may mis-evaluate token types where the relative threat posed by syntactic versus semantic exposure differs materially. For example, a JWT token is primarily at risk from automated decoders that inspect the payload, suggesting w_1 (syntactic) and w_2 (semantic) should carry different relative weights than for an `.env` file examined by a human operator. Ding et al. [7] demonstrate in the context of LLM agent evaluation that task-adaptive rubrics with per-task weight profiles can substantially reduce systematic mis-evaluation. Applying this principle to honeytoken assessment—deriving token-type-specific weight vectors from an analysis of attacker inspection patterns—is a priority for future versions of the B framework, and would also provide a natural way to decouple the currently shared organisational-term signal across components discussed in Sect. 7.3.

7.5 Adversarial LLM scanners

The three scanner models employed (regex, entropy, ML) represent the state of currently deployed secret-scanning technology, simulated rather than instantiated from real tools (Sect. 5.4). However, a qualitatively different threat is emerging: adversarial use of large language models for reconnaissance, in which an LLM analyses credential files not by pattern or entropy but by semantic intent—asking, in effect, “does this credential look like it belongs here?” Zhang et al. [25] demonstrate that intention-analysis mechanisms substantially improve LLM resilience to adversarial inputs, and the dual-use implication for credential scanning is direct: the same intent-parsing capability that defends an LLM against jailbreaks can identify honeytokens that lack coherent operational context. PHANTOM's org-injection approach may provide a structural defence against this class of scanner—embedding genuine-looking provenance into every field—but empirical evaluation against deployed LLM-based scanners, real secret-scanning tools (trufflehog, gitleaks, GitGuardian), and human red-team experts is required to confirm this intuition and is a primary direction for future work.

7.6 Air-gap deployability

A practical advantage of PHANTOM over LLM-based approaches is deployability in restricted environments. Classified government networks, industrial control systems, and financial clearing infrastructure routinely prohibit outbound API calls. PHANTOM's rule-based contextual generator achieves $B = 0.778$ under our own rule-based evaluator; we make no claim of parity with what an LLM-based generator would achieve, since no such comparison was run in this study, without any network dependency. This makes it deployable alongside Passive Hack-Back [21] in the most sensitive operational contexts.

7.7 Limitations and future work

Scale of evaluation. The experiment uses $n = 32$ tokens per method across 4 simulated profiles, one instance per token-type—organisation pair. Despite large effect sizes, this sample is insufficient to claim statistical robustness in the general case, and provides no estimate of within-cell variance. A larger-scale evaluation with multiple independently seeded instances per cell and with real human security professionals (IRB-approved study) would provide genuine S_h measurements and allow assessment of variability across a wider range of organisational and token-type configurations.

Circularity of the evaluation instruments. As discussed in Sect. 7.3, the semantic (S_c), human-acceptance-proxy (S_h), and simulated ML-classifier (S3) scores are correlated by construction, since all three reward the presence of organisational terms that PHANTOM's generator was explicitly designed to inject. This is the most significant threat to the validity of the reported gains and should be resolved before the magnitude of these gains is relied upon.

Adversarial attackers. The scanner models are representative but not exhaustive, and are simulated rather than real, independently trained tools. Sophisticated attackers may use LLM-based scanners tuned to detect semantic inconsistencies that go beyond pattern matching and entropy. Evaluation against these intent-parsing adversaries [25], and against real tools such as trufflehog, gitleaks, and GitGuardian, real red-team experts, and LLM-based attackers, is a critical gap.

Dynamic context. PHANTOM currently uses a static organisational profile. Real deployments evolve: services are renamed, teams restructure, cloud regions change. An adaptive variant that reads live context from infrastructure-as-code repositories (Terraform, Helm charts) would maintain freshness.

Adaptive, token-type-specific scoring. Different token types carry different risks and are inspected differently by attackers and tooling, and should not necessarily share one fixed rubric. Extending B to support token-type-specific weight profiles, informed by the ADARUBRIC approach [7],

is required to avoid systematic mis-evaluation of token types with atypical inspection patterns, and would also help decouple the shared organisational-term signal discussed above.

Sample size and statistical design. The current $n = 32$, single-instance-per-cell design should be extended to multiple independently seeded replicates per type—organisation pair in future work, to support proper within-cell variance estimates and more conservative inference.

Integration with attribution. PHANTOM honeytokens are natural complements to the Passive Hack-Back attribution framework [21] and the ARCANE longitudinal re-identification system [22]. A deployed PHANTOM token that fires provides the callback telemetry that ARCANE needs to accumulate cross-campaign fingerprints. The three systems form a complete post-exfiltration attribution pipeline.

8 Conclusion

We presented *PHANTOM*, a contextual honeytokens generation framework that addresses the critical limitation of existing tools: the absence of organisational specificity. By encoding domain names, service architectures, technology stack idioms, and credential naming conventions directly into each generated token, PHANTOM achieves a Believability Score of $B = 0.778$ versus 0.576 for static templates ($d = 3.52$, $p < 0.001$), with 100% of tokens passing the heuristic acceptance threshold compared to 6.2% for templates, *as measured by the rule-based evaluation instruments*. These results are based on a controlled evaluation of $n = 32$ tokens per method with one instance per type—organisation pair; large-scale validation with human raters, real secret-scanning tools, and adversarial LLM-based scanners remains as future work, and is necessary before the magnitude of the reported gains can be treated as evidence of real-world effectiveness rather than of internal consistency between the generator and the evaluator.

The dominant driver is semantic coherence ($\Delta S_c = +0.309$, $d = 4.52$), consistent with the hypothesis that context is an important missing dimension in honeytokens generation, though this finding shares the circularity limitation discussed above and should be read as evidence that the intended mechanism operates as designed rather than as independent confirmation. Detection resistance improves by $+0.261$ ($d = 7.49$), with the largest gap on the simulated ML-classifier scanner—by construction the paradigm most responsive to the organisational-term signal that PHANTOM injects.

PHANTOM operates without external API calls, making it suitable for deployment in air-gapped environments. Combined with Passive Hack-Back-style beacon infrastructure and longitudinal attribution, PHANTOM offers a candidate bait component for a post-exfiltration deception and attribution pipeline, pending the independent evalua-

tion identified above. Future extensions will address adaptive scoring weights, dynamic organisational profiles, real secret-scanning tools, human-subject studies, and evaluation against LLM-driven adversarial scanners.

Author Contributions A.I.W. is the sole author and is responsible for the study conception, design, methodology, software development, data collection, analysis, and preparation of the manuscript.

Funding The author declares that no funds, grants, or other support were received during the preparation of this manuscript.

Data Availability No datasets were generated or analysed during the current study.

Declarations

Ethical standard The author has complied with the ethical standards of the journal. This research involved no human participants or animals.

Conflict of interest The author has no relevant financial or non-financial interests to disclose.

Open Access This article is licensed under a Creative Commons Attribution-NonCommercial-NoDerivatives 4.0 International License, which permits any non-commercial use, sharing, distribution and reproduction in any medium or format, as long as you give appropriate credit to the original author(s) and the source, provide a link to the Creative Commons licence, and indicate if you modified the licensed material. You do not have permission under this licence to share adapted material derived from this article or parts of it. The images or other third party material in this article are included in the article's Creative Commons licence, unless indicated otherwise in a credit line to the material. If material is not included in the article's Creative Commons licence and your intended use is not permitted by statutory regulation or exceeds the permitted use, you will need to obtain permission directly from the copyright holder. To view a copy of this licence, visit <http://creativecommons.org/licenses/by-nc-nd/4.0/>.

References

1. Almeshekah, M.H., Spafford, E.H.: Cyber security deception. In: *Cyber Deception: Building the Scientific Foundation*, pp. 23–50. Springer (2016)
2. Basak, S.K., Cox, J., Reaves, B., Williams, L.: A comparative study of software secrets reporting by secret detection tools. In: *2023 ACM/IEEE International Symposium on Empirical Software Engineering and Measurement (ESEM)*, pp. 1–12. IEEE (2023)
3. Beltrán-López, P., Pérez, M.G., Nespole, P.: Cyber deception: taxonomy, state of the art, frameworks, trends, and open challenges. *IEEE Commun. Surv. Tutor* **28**, 1520–1556 (2026)
4. Botacin, M.: Gp threats-3: Is automatic malware generation a threat? In: *2023 IEEE Security and Privacy Workshops (SPW)*, pp. 238–254. IEEE (2023)
5. Constâncio, A.S., Tsunoda, D.F., Silva, H.D.F.N., Silveira, J.M.D., Carvalho, D.R.: Deception detection with machine learning: a systematic review and statistical analysis. *PLoS ONE* **18**(2), e0281323 (2023)
6. Deng, G., Liu, Y., Mayoral-Vilches, V., Liu, P., Li, Y., Xu, Y., Zhang, T., Liu, Y., Pinzger, M., Rass, S.: Pentestgpt: an llm-empowered automatic penetration testing tool (2023). [arXiv:2308.06782](https://arxiv.org/abs/2308.06782) arXiv preprint

7. Ding, L.: Adarubric: task-adaptive rubrics for reliable llm agent evaluation and reward learning (2026). [arXiv:2603.21362](https://arxiv.org/abs/2603.21362) arXiv preprint
8. Fang, R., Bindu, R., Gupta, A., Kang, D.: Llm agents can autonomously exploit one-day vulnerabilities (2024). [arXiv:2404.08144](https://arxiv.org/abs/2404.08144) arXiv preprint
9. GitGuardian. State of secrets sprawl.: 2023. Tech, Rep (2023)
10. Irfan, M., Sadighian, A., Tanveer, A., Shaikha, J., Al-Naimi, G., Oligeri: False data injection attacks in smart grids: State of the art and way forward (2023). [arXiv:2308.10268](https://arxiv.org/abs/2308.10268) arXiv preprint
11. Juels, A., Rivest, R.L.: Honeywords: Making password-cracking detectable. In: Proceedings of the 2013 ACM SIGSAC Conference on Computer & Communications Security, pp. 145–160 (2013)
12. Kabiden, D.: Canary tokens as a strategic component in cybersecurity defense and red teaming. *TSARKA Sci.* **1**, 26–36 (2026)
13. Karanjai, R.: Targeted phishing campaigns using large scale language models, (2022). [arXiv:2301.00665](https://arxiv.org/abs/2301.00665) arXiv preprint
14. Karlsen, E., Luo, X., Zincir-Heywood, N., Heywood, M.: Benchmarking large language models for log analysis, security, and interpretation. *J. Netw. Syst. Manag.* **32**(3), 59 (2024)
15. Muir, J.A., Oorschot, P.C.V.: Internet geolocation: evasion and counterevasion. *Acm Comput. Surv. (CSUR)* **42**(1), 1–23 (2009)
16. Rana, M.U., Ellahi, O., Alam, M., Webber, J.L., Mehbodniya, A., Khan, S.: Offensive security: cyber threat intelligence enrichment with counterintelligence and counterattack. *IEEE Access* **10**, 108760–108774 (2022)
17. Rice, Z.: Gitleaks: A static application security testing tool for detecting secrets in git repositories. <https://github.com/gitleaks/gitleaks>, (2018). Open-source SAST tool for detecting hardcoded secrets such as API keys, passwords, and tokens in Git repositories; first released in 2018 and actively maintained
18. Shu, X., Yao, D., Ramakrishnan, N.: Unearthing stealthy program attacks buried in extremely long execution paths. In: Proceedings of the 22nd ACM SIGSAC Conference on Computer and Communications Security, pp. 401–413 (2015)
19. Spitzner, L.: Honeypots: Catching the insider threat. In: 19th Annual Computer Security Applications Conference, 2003. Proceedings, pp. 170–179. IEEE (2003)
20. WebBreach. Recon-ng: Open Source Intelligence Gathering Tool. <https://github.com/lanmaster53/recon-ng> (2014). Accessed 21 Apr 2026
21. Weinberg, A.I.: Passive hack-back strategies for cyber attribution: Covert vectors in denied environment (2025). [arXiv:2508.16637](https://arxiv.org/abs/2508.16637) arXiv preprint
22. Weinberg, A.I.: Arcane: cross-campaign attacker re-identification via passive beacon telemetry-a bayesian network framework for longitudinal cyber attribution (2026). [arXiv:2604.24644](https://arxiv.org/abs/2604.24644) arXiv preprint
23. Wiedeman, C., Wang, G.: Disrupting adversarial transferability in deep neural networks. *Patterns* **3**(5) (2022)
24. Tianxiang, Yu., Xin, Y., Zhang, C.: Honeyfactory: container-based comprehensive cyber deception honeynet architecture. *Electronics* **13**(2), 361 (2024)
25. Zhang, Y., Ding, L., Zhang, L., Tao, D.: Intention analysis makes llms a good jailbreak defender. In: Proceedings of the 31st International Conference on Computational Linguistics, pp. 2947–2968 (2025)

Publisher's Note Springer Nature remains neutral with regard to jurisdictional claims in published maps and institutional affiliations.